CASE STUDY

# PHP2Shell and the October 2026 Attack Wave: A Case Study

*A TeamStarWolf case study. Published 3 November 2026; every source checked as of that date.*

## Executive summary

October 2026 compressed several years' worth of trust failures into a few weeks. The centerpiece was PHP2Shell: two pre-authentication remote-code-execution flaws in PHP itself (CVE-2026-109618 and CVE-2026-109619), disclosed on 20–21 October and exploited at internet scale within the hour. Around it, three trust layers failed in roughly 72 hours (the web runtime, the Web PKI, and the software and SaaS supply chain), the largest cryptocurrency theft in history drained about $6.3 billion from Binance, a trojanized build of an AI coding extension planted SSH backdoors on developer machines, and a dense cluster of Japanese consumer breaches ran in parallel. Agentic AI appeared on both sides of the ledger, as an attacker accelerant and as a target.

> Evidence grade: **Confirmed** overall (vendor, government and primary-research sources for each major item; single-source or claimed figures are marked below).

### Key facts at a glance

| Field | Value |
|---|---|
| Centerpiece | PHP2Shell: CVE-2026-109618 and CVE-2026-109619, pre-auth RCE in PHP core, CVSS v4.0 9.2 |
| Affected | PHP 5.4 through 8.5; fixed in 8.5.12, 8.4.27, 8.3.36 and 8.2.35 (20 to 21 October 2026) |
| Exploitation speed | Honeypot attempts four days before disclosure; tens of thousands of attempts within 45 minutes, millions within a day |

| Field | Value |
|---|---|
| SaaS supply chain | ConnectWise Cloud Backup via stolen OAuth credential (Storm-0940, agentic framework ARTEX, about 2,900 sign-ins a minute) |
| Web PKI | Eight eMudhra intermediate CA keys distrusted (see the dedicated study) |
| Largest crypto theft | About $6.3 billion from Binance, North Korea's TraderTraitor, most moved in about 20 minutes |
| AI toolchain hits | Trojanized LiteLLM 1.107.0 (un-rotated May key) and a malicious "Claude Code" Cursor extension |
| Confirmed breach? | As of CISA's advisory, mass PHP2Shell scanning but no confirmed successful compromise |

## Key findings

- **PHP2Shell put every PHP web server in scope.** Two memory-corruption bugs in PHP core (a use-after-free in the upload-progress feature and a partial-initialization fault under memory pressure) allow unauthenticated RCE. They affect PHP 5.4 through 8.5 and were fixed in 8.5.12, 8.4.27, 8.3.36 and 8.2.35.
- **Exploitation beat disclosure.** Amazon's MadPot sensors saw attempts on 17 October, four days before the public advisory. Cloudflare measured tens of thousands of attempts within 45 minutes of disclosure, rising to millions. Payloads included a Mirai fork and web-shell drops; as of CISA's advisory, no successful compromise had been confirmed.
- **Supply chain and SaaS identity were the dominant vector.** Microsoft attributed the ConnectWise Cloud Backup compromise to China-aligned Storm-0940, which abused a stolen OAuth application credential to reach Microsoft 365 tenants at about 2,900 sign-ins a minute using the agentic-AI pentest framework ARTEX. A trojanized LiteLLM 1.107.0 reached PyPI and container registries after a master key leaked months earlier and was never rotated.
- **The record Binance heist was North Korean.** The FBI attributed the theft of more than $6 billion in virtual assets on 29 October to the actor it tracks as TraderTraitor; Binance put the figure at about $6.3 billion, most of it moved in roughly 20 minutes, with around $3 billion in stablecoins later frozen.
- **AI was both weapon and target.** Storm-0940 used ARTEX to speed the ConnectWise intrusion, while a trojanized "Claude Code" extension in the Cursor marketplace and the poisoned LiteLLM package attacked the AI toolchain itself.

## Top recommendations

1. Patch PHP now to a fixed release and inventory every PHP surface, including appliances and bundled interpreters; a WAF rule is a stopgap, not a fix.
2. Treat SaaS application credentials (OAuth app secrets, API keys) as privileged identities: rotate on any provider incident, scope tightly, and alert on high-rate non-interactive sign-ins.

3 Govern AI developer tooling like any other supply-chain dependency: pin versions, verify publisher and marketplace integrity, and watch for persistence (SSH keys, reverse tunnels) that survives uninstall.

4 Keep a software bill of materials and rotate leaked keys on disclosure, not on a schedule; the LiteLLM compromise turned an un-revoked May key into an October incident.

## Scope and method

This study covers PHP2Shell and the broader October 2026 incident wave, from vendor, government and primary-research sources, cross-checked against the Team Star Wolf Intelligence Hub weekly report for 2026-W43. Each claim carries one of three evidence grades.

| Grade | Meaning |
|---|---|
| Confirmed | A vendor, CISA KEV, government agency, or the primary research team confirms the exploitation or compromise |
| Reported | Attempts or claims exist, but no primary source confirms a successful compromise |
| Demonstrated | A research reconstruction with no known in-the-wild use |

## Part 1: PHP2Shell (CVE-2026-109618, CVE-2026-109619)

PHP2Shell is the name researchers gave to two critical flaws in PHP core, each rated CVSS v4.0 9.2 (**Confirmed**: PHP project advisory). Both can give unauthenticated remote code execution to any PHP installation serving web requests.

- **CVE-2026-109619**: a use-after-free in PHP core's upload-progress feature.
- **CVE-2026-109618**: memory corruption when an out-of-memory condition interrupts PHP while internal request data is only partially initialized.

The flaws affect PHP 5.4 through 8.5, which is effectively the entire supported and legacy range, and were fixed in PHP 8.5.12, 8.4.27, 8.3.36 and 8.2.35, released 20–21 October 2026. CISA, NSA and NCSC-UK told organizations to patch or take PHP servers offline (**Confirmed**).

Why PHP2Shell was so alarming is PHP's ubiquity. PHP still runs a large share of the web, from bespoke applications to the content-management systems, forums and admin panels that sit on the internet edge, and it is embedded inside countless vendor appliances and container images where operators may not even think of it as "their" PHP. A pre-authentication memory-corruption flaw in the interpreter itself therefore does not have a tidy asset list; the attack surface is "anything serving PHP," which is why the advisories reached for the blunt instruction to patch or take the server offline.

The timeline is the lesson. Amazon Threat Intelligence observed exploitation attempts in its MadPot honeypots on 17 October, four days before public disclosure (**Confirmed**: Amazon). watchTowr reported in-the-wild exploitation of both CVEs (**Reported**). Cloudflare measured tens of thousands of attempts within about 45 minutes of the announcement, climbing to millions by 22 October (**Confirmed**: Cloudflare telemetry).

Observed payloads included a Mirai botnet fork (Nokia Deepfield) and attempts to drop a web shell through a server-side session file from a China-based address (**Reported**). As of CISA's advisory, no successful compromise had been confirmed, which separates mass scanning from mass breach, and is the distinction a defender has to hold onto when the attempt count runs to the millions.

## October 2026 timeline

| Date | Event |
|---|---|
| 14 October | ConnectWise identifies the Cloud Backup issue |
| 17 October | Amazon MadPot sees PHP2Shell attempts; ConnectWise suspends Cloud Backup |
| 20 to 21 October | PHP2Shell disclosed and patched; eMudhra intermediate CA keys distrusted by browsers |
| By 22 October | PHP2Shell exploit attempts climb from tens of thousands to millions |
| 29 October | Binance drained of about $6.3 billion (TraderTraitor); trojanized "Claude Code" Cursor extension published |
| Throughout the week | CISA adds eight CVEs to KEV; the Japanese consumer-breach cluster unfolds |

## PHP2Shell remediation

| Surface | How to remediate |
|---|---|
| PHP runtime | Upgrade to PHP 8.5.12 / 8.4.27 / 8.3.36 / 8.2.35 or later; distributions have backported the fix, so check the package, not only the banner ( `php -v` , `dpkg -l php*` or `rpm -q php` ) |
| Web servers | Patch the PHP that each server embeds: mod_php, PHP-FPM, and any interpreter bundled in an appliance or container image; restart the service after patching |
| Containers / CI | Rebuild images from patched base packages, pin by digest, redeploy, and scan images and SBOMs for vulnerable PHP versions |
| Appliances and products | Many vendor products embed PHP; apply the vendor's PHP2Shell advisory rather than assuming the OS patch covers it |
| Interim only | A WAF or mod_security rule can blunt the public payloads but does not close the memory-corruption flaw; treat it as time bought, not a fix |

## Per-platform and per-software remediation

The by-surface table above says what to fix; this one says how, per platform and per software stack. In every case, after upgrading the PHP packages, restart the service that embeds PHP (PHP-FPM, the web server, or the app container), because a long-running process keeps the old interpreter in memory (**Confirmed** as general guidance from the PHP advisory and distributions):

| Platform or software | How to remediate |
|---|---|
| Debian / Ubuntu | `dpkg -l 'php*'` ; `sudo apt-get update && sudo apt-get install --only-upgrade php*` to the backported fix, then restart PHP-FPM or Apache |
| RHEL / Alma / Rocky | `rpm -q php` ; `sudo dnf upgrade php\*` (or the Remi module if used), then `systemctl restart php-fpm httpd` |
| Alpine (common in containers) | `apk info -v php8*` ; `apk upgrade php8*` , then rebuild the image rather than patching a running container |
| Windows | Replace the PHP binaries with a patched 8.5.12 / 8.4.27 / 8.3.36 / 8.2.35 build and restart IIS or the FastCGI handler |
| PHP-FPM vs mod_php | Confirm which model each host uses ( `php -v` reports the CLI, not the web SAPI); upgrade the matching package and restart the web SAPI, not only the CLI |
| Docker and container images | Rebuild from a patched `php` base image, pin by digest, redeploy all replicas, and scan images and SBOMs for vulnerable PHP |
| WordPress, Drupal, Laravel and other PHP apps | Patch the underlying PHP runtime, not just the application or its plugins; a current app on an unpatched interpreter is still exposed |
| Managed and shared hosting (cPanel, Plesk) | Apply the host's PHP update (for example through EasyApache or the MultiPHP manager) across every PHP version offered |
| Vendor appliances and products | Apply the vendor's PHP2Shell advisory for any product that embeds PHP, rather than assuming an OS patch reaches it |
| WAF (interim only) | A rule blunting the public payloads buys time but does not close the memory-corruption flaw; keep patching |

## Part 2: three trust layers in 72 hours

The Intelligence Hub's 2026-W43 report frames the week of 19–25 October as three distinct trust layers failing almost at once.

1. **The web runtime.** PHP2Shell, above.

2. **The Web PKI.** Eight eMudhra (emSign) intermediate CA private keys were generated with almost no entropy, one effectively the integer 4, and browser and OS vendors distrusted them on 20–21 October; eMudhra then announced it would leave the TLS business. This has its own full write-up in The eMudhra Certificate Authority Key Compromise (**Confirmed**).
3. **The software and SaaS supply chain.** Microsoft attributed the ConnectWise Cloud Backup compromise to Storm-0940 (**Confirmed**: Microsoft). A stolen OAuth application credential let the actor sign into customer Microsoft 365 tenants at about 2,900 attempts a minute, with no interactive login, using the agentic-AI pentest framework ARTEX; ConnectWise identified the issue on 14 October and suspended the service on 17 October, and says the stored backups themselves were not accessed. In parallel, LiteLLM 1.107.0 was trojanized on PyPI and in container registries after a master key that leaked in May was never revoked (**Confirmed**).

Alongside these, CISA added eight CVEs to its Known Exploited Vulnerabilities catalog that week (Plex, SiteGuard, Siemens Software Center, Arista VeloCloud Orchestrator, and Collabora CODE), none flagged for known ransomware use, and CISA and the FBI issued a #StopRansomware advisory on the SafePay group (**Confirmed**).

## Part 3: the wider October landscape

- **Binance, the largest crypto heist on record (29 October).** The FBI attributed the theft of more than $6 billion to North Korea's TraderTraitor; Binance stated about $6.3 billion, most of it laundered in roughly 20 minutes, with around $3 billion in stablecoins frozen (**Confirmed**: FBI alert, Binance, Chainalysis and TRM analysis).
- **A trojanized AI coding extension (29 October).** Malicious builds 2.1.312 and 2.1.313 of a "Claude Code" extension sat in the Cursor marketplace for about 11 hours, planting an attacker SSH key and a reverse tunnel that survived uninstalling the extension; up to 5,000 users were exposed. The builds were not produced by Anthropic, and Cursor rebuilt its marketplace in response (**Confirmed**: Sophos, Microsoft, Cursor). A claim that the upload followed a breach at Anthropic is an unverified allegation (**Reported**).
- **A cluster of Japanese breaches.** Sony's So-net and plala disclosed 2,585,481 exposed records (**Confirmed**); Burger King Japan disclosed about 11.18 million app records accessed between 2 and 7 October (**Confirmed**); Japanese cloud provider IDC Frontier's IDCF Cloud was disrupted by ransomware on 7–8 October, affecting 495 organizations (the 3.6 PB "encrypted" figure is an attacker claim, **Reported**); Advantest, Japan Airlines (about 90,000 passengers via a third party), and GMO were also hit (**Confirmed** / **Reported** by source).
- **Other notable items.** A Florida financial-aid site breach exposed Social Security numbers for about 4.9 million people (**Reported**); ASOS confirmed a customer-data breach (**Confirmed**); the GlassWorm campaign abused OVHcloud GitHub infrastructure, and the Railway platform reported a supply-chain incident (**Reported**).

## Part 4: the vulnerability-management lens

The October wave is a stress test of a vulnerability management program's reflexes, and each strand points at a different muscle:

- **Ubiquitous-runtime flaws need a surface map, not a host list.** PHP2Shell cannot be chased host by host, because PHP hides inside appliances, images and bundled stacks. The program that coped was the one that could answer "where does PHP run, including inside products we bought," from a software inventory and SBOMs, rather than a server list. Scan the package and the embedded interpreter, not just the banner.
- **SaaS application credentials are privileged identities.** The ConnectWise intrusion ran on a stolen OAuth application secret, not a user password, and moved at machine speed with no interactive login. Treat app secrets and API keys like privileged accounts: scope them tightly, rotate them on any provider incident, and alert on high-rate non-interactive sign-ins, which is the signal a 2,900-per-minute agentic run produces.
- **Leaked keys are incidents the moment they leak, not when they are abused.** The LiteLLM master key leaked in May and became an October breach because it was never rotated. Rotation on disclosure, not on a calendar, is the control that would have closed that gap.
- **Developer tooling is supply chain.** The trojanized LiteLLM package and the malicious Cursor extension both entered through the developer's own toolchain, and the extension's SSH-key and reverse-tunnel persistence survived uninstalling it. Pin versions, verify publisher and marketplace integrity, and hunt for persistence that outlives the package.

### Detection and hunting

- **PHP servers**: watch for the public payload shapes (the Mirai fork, web-shell drops via session files), confirm the patched package is installed and the service restarted, and treat a spike of malformed upload-progress or session traffic as worth investigating.
- **SaaS tenants**: alert on non-interactive sign-ins at high rate, new or unexpected OAuth application consents, and token use from unfamiliar infrastructure.
- **Developer endpoints**: inventory installed editor extensions and their versions, and hunt for unexpected SSH keys and outbound reverse tunnels that persist after an uninstall.

See the Vulnerability Prioritization Reference and the Supply Chain Security Reference.

## Cross-cutting themes

- **The supply chain was the main battlefield.** PHP2Shell (a shared runtime), eMudhra (shared trust roots), ConnectWise (shared SaaS identity), LiteLLM and the Claude Code extension (shared developer tooling) all turned one compromise into many victims.
- **Agentic AI is on both sides.** Storm-0940 used ARTEX to move faster than human-paced response; the AI toolchain itself (the extension, LiteLLM) was a target. Treat AI-assisted intrusion speed as a planning assumption.
- **Speed is the defining metric.** PHP2Shell went from disclosure to millions of exploit attempts in hours, and the Binance funds moved in about 20 minutes. Containment that waits for human approval loses this race.
- **Identity and keys are the soft center.** The ConnectWise OAuth secret and the un-rotated LiteLLM master key each converted a stored credential into a breach; key rotation on disclosure is not optional.

## Sources

- PHP project security advisory and release notes for 8.5.12 / 8.4.27 / 8.3.36 / 8.2.35; Amazon Threat Intelligence (MadPot), Cloudflare, watchTowr, Akamai, Qualys and Arctic Wolf analyses of PHP2Shell.
- Microsoft and ConnectWise advisories on the Cloud Backup compromise and Storm-0940; the LiteLLM project and PyPI advisories.
- The FBI alert on the Binance theft, with Binance, Chainalysis and TRM analysis, and reporting from Al Jazeera, NPR and BleepingComputer.
- Sophos, Microsoft and Cursor on the trojanized Claude Code extension; company disclosures for the Sony So-net, Burger King Japan, IDC Frontier, Japan Airlines and ASOS breaches.
- The Team Star Wolf Intelligence Hub weekly report 2026-W43, which cross-references these items to their primary sources.

## Related references

- The eMudhra Certificate Authority Key Compromise
- The XZ Utils Backdoor
- AI Threats: a 2026 Case Study
- Supply Chain Security Reference, Web Application Security Reference, Notable Incidents